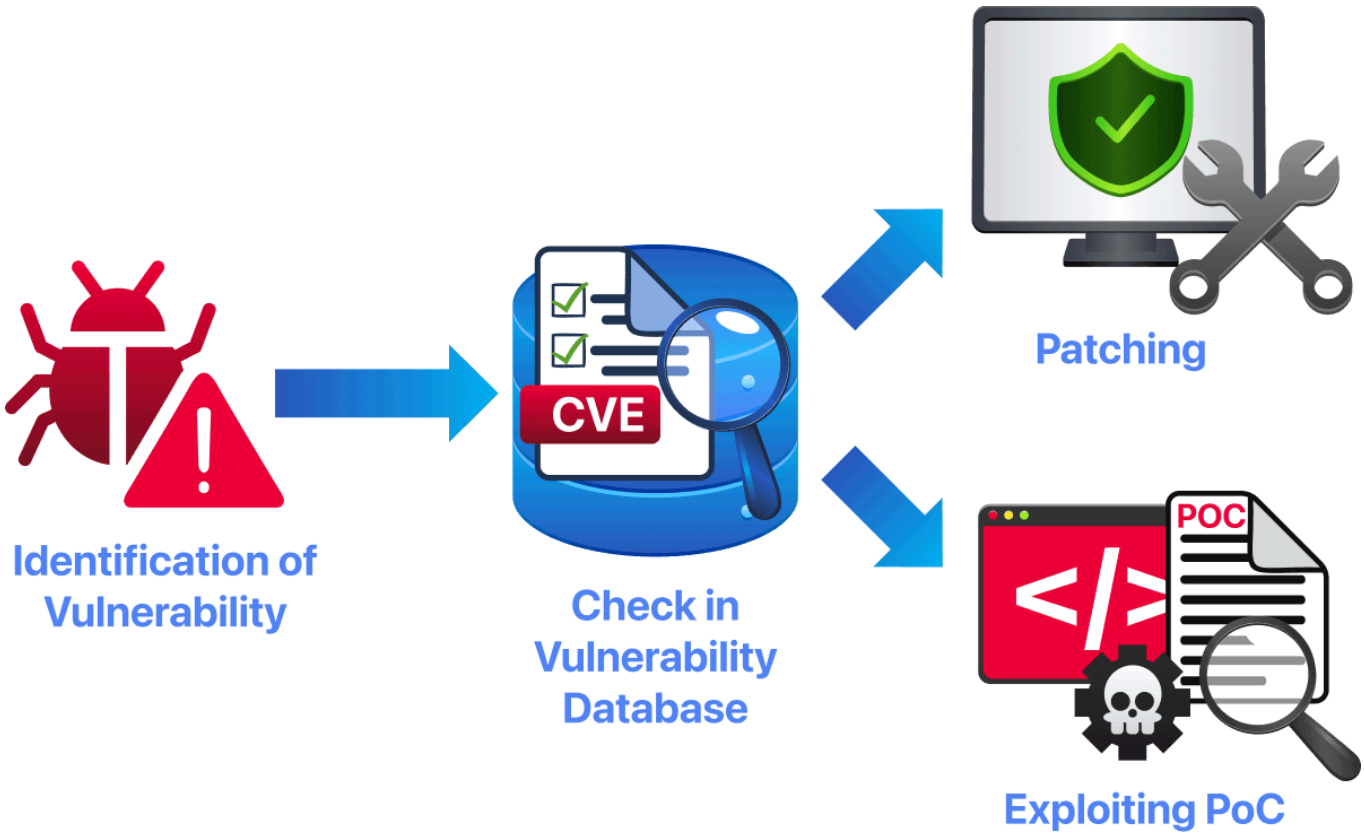
Understanding Vulnerability Databses

Why We Use Vulnerability Databases

They help security professionals:

- Avoid duplicate research by referencing known issues
- Use consistent naming for vulnerabilities across tools and teams
- Stay aware of available patches and security advisories



Key Building blocks



Vulnerability Identifier (CVE)

A vulnerability identifier uniquely identifies a known security flaw so it can be tracked consistently across tools and databases. The most widely used identifier is the Common Vulnerabilities and Exposures (CVE) system(opens in new tab)

Severity Representation (CVSS)

Severity in vulnerability databases is represented using the Common Vulnerability Scoring System (CVSS)(opens in new tab). CVSS assigns a numerical score that reflects how easily a vulnerability can be exploited and the potential impact if it is successfully abused

Affected Product Identification (CPE)

Vulnerability databases identify affected software using Common Platform Enumeration (CPE) (opens in new tab), which provides a standardised naming format for vendors, products, and versions to clearly define what is vulnerable.

Common Weakness Enumeration (CWE)

Vulnerability databases also classify the underlying weakness that caused a security issue using Common Weakness Enumeration (CWE), which groups vulnerabilities by root cause, helping security professionals understand why a flaw exists, not just what is affected.

CVE Numbering Authorities (CNA)

CVE Numbering Authorities (CNAs)(opens in new tab) are organisations authorised to assign CVE identifiers to newly discovered vulnerabilities. CNAs help scale the CVE program by allowing vendors and organisations to report vulnerabilities in their own products directly.

Vulnerability Metadata

In addition to identifiers and severity scores, vulnerability entries include metadata such as a technical description, reference links, and remediation information. This data helps users understand the vulnerability and locate trusted guidance.

Severity vs Risk

Severity describes the technical impact of a vulnerability, while risk considers how that vulnerability affects a specific environment. Risk depends on factors such as system exposure, usage, and business importance. Example: A high-severity vulnerability on an isolated test system presents lower risk than a medium-severity vulnerability on an internet-facing production server.

Types of Vulnerability DBs: CVE List

The CVE List is a public catalogue of known security vulnerabilities that provides a unique identifier for each issue. Its primary purpose is to ensure that every vulnerability can be consistently referenced across tools, reports, and databases.

Each CVE entry provides a standardised identifier, a brief description of the vulnerability, and information about affected vendors or products, allowing security professionals to recognise and reference an issue quickly. The CVE List may also include severity scores and version details when provided by the assigning authority.

Types of Vulnerability DBs: National Vulnerability Database (NVD)

The National Vulnerability Database (NVD) is a public vulnerability database maintained by the National Institute of Standards and Technology (NIST). It builds upon the CVE List by enriching CVE entries with additional analysis, scoring, and structured data.

The NVD enhances CVE records by adding CVSS severity scoring, CPE-based affected product mappings, and impact metrics.

https://nvd.nist.gov/vuln/search#/nvd/home?resultType=records

Types of Vulnerability DBs: Other Public VDBs

Exploit-focused databases, such as ExploitDB, concentrate on proof-of-concept exploits and real-world attack techniques. Penetration testers and red teamers commonly use these databases to understand how vulnerabilities can be practically exploited.

Vendor security advisories are published directly by software vendors and provide authoritative information about vulnerabilities in their products. These advisories often include patch availability, mitigation steps, and recommended upgrade paths, making them valuable for defenders and system administrators.

Community-driven and regional databases collect vulnerability information from open-source contributors, researchers, or region-specific CERTs. These databases may surface issues earlier than official sources or provide additional context not found elsewhere.

https://www.exploit-db.com/search